

ID	Инструмент	Тип уязвимости / Правило	Файл или компонент	Severity (ориг.)	EPSS	KEV	Предлагаемое решение	Обоснование	Приор.
OSV-001	OSV-Scanner	CVE-2024-50379 (Tomcat TOCTOU RCE)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.865	0	Обновить tomcat-embed-core до 10.1.34+ (или Spring Boot до 3.2.6+)	TP: известная RCE при включённой записи в default servlet, исправляется обновлением	P0
OSV-002	OSV-Scanner	CVE-2025-24813 (Tomcat path equivalence RCE)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.942	0	Обновить tomcat-embed-core до 10.1.35+	TP: обход ограничений через partial PUT, позволяет выполнить код, исправляется обновлением	P0
OSV-003	OSV-Scanner	CVE-2026-43512 (Tomcat digest auth bypass)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.001	0	Обновить tomcat-embed-core до 10.1.55+	TP: любой неизвестный пользователь аутентифицируется с паролем «null», исправляется обновлением	P0
OSV-004	OSV-Scanner	CVE-2026-41293 (Tomcat HTTP/2 header validation)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.001	0	Обновить tomcat-embed-core до 10.1.55+	TP: отсутствие валидации заголовков HTTP/2 может привести к RCE, исправляется обновлением	P0
OSV-005	OSV-Scanner	CVE-2025-55754 (Tomcat ANSI escape injection)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.002	0	Обновить tomcat-embed-core до 10.1.45+	TP: инъекция ANSI-последовательностей в логи, возможен обман администратора, исправляется обновлением	P0
OSV-006	OSV-Scanner	CVE-2026-43515 (Tomcat security constraints bypass)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.001	0	Обновить tomcat-embed-core до 10.1.55+	TP: некорректное применение security constraints при нескольких методах, исправляется обновлением	P0
OSV-007	OSV-Scanner	CVE-2025-66614 (Tomcat client cert bypass)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	CRITICAL	0.001	0	Обновить tomcat-embed-core до 10.1.50+	TP: обход проверки клиентского сертификата через SNI mismatch, исправляется обновлением	P0
OSV-008	OSV-Scanner	CVE-2025-12183 (LZ4 Java OOB read)	orders-service/pom.xml, payments-service/pom.xml (lz4-java:1.8.0)	HIGH	0.001	0	Обновить lz4-java до 1.8.1 (группа at.yawk.lz4)	TP: чтение за границы буфера при декомпрессии, может привести к DoS или утечке, исправляется обновлением	P1
OSV-009	OSV-Scanner	CVE-2025-48734 (Commons BeanUtils enum access)	payments-service/pom.xml (commons-beanutils:1.9.4)	HIGH	0.002	0	Обновить commons-beanutils до 1.11.0+	TP: доступ к класслоадеру через declaredClass у enum, может привести к RCE, исправляется обновлением	P1
OSV-010	OSV-Scanner	CVE-2025-27818 (Kafka Connect deserialization RCE)	payments-service/pom.xml (kafka_2.13:3.6.2)	HIGH	0.006	0	Обновить kafka-clients до 3.9.1+ (и kafka_2.13 соответственно)	TP: неограниченная десериализация через LdapLoginModule в Kafka Connect, исправляется обновлением	P1
OSV-011	OSV-Scanner	CVE-2026-35554 (Kafka producer race condition)	orders-service/pom.xml, payments-service/pom.xml (kafka-clients:3.6.2)	HIGH	0.001	0	Обновить kafka-clients до 3.9.2+	TP: гонка при управлении буферами приводит к порче и переадресации сообщений, исправляется обновлением	P1
OSV-012	OSV-Scanner	CVE-2025-48988 (Tomcat multipart DoS)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	HIGH	0.001	0	Обновить tomcat-embed-core до 10.1.42+	TP: DoS через multipart upload, исправляется обновлением	P1
OSV-013	OSV-Scanner	CVE-2024-34750 (Tomcat HTTP/2 DoS)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	HIGH	0.173	0	Обновить tomcat-embed-core до 10.1.25+	TP: DoS через неправильный учёт потоков HTTP/2, исправляется обновлением	P1
OSV-014	OSV-Scanner	CVE-2026-24308 (ZooKeeper config exposure)	payments-service/pom.xml (zookeeper:3.8.4)	HIGH	0.001	0	Обновить zookeeper до 3.8.6+	TP: конфигурационные значения логируются в INFO, могут раскрыть секреты, исправляется обновлением	P1
OSV-015	OSV-Scanner	CVE-2024-47554 (Commons IO XML bomb)	payments-service/pom.xml (commons-io:2.11.0)	HIGH	0.001	0	Обновить commons-io до 2.14.0+	TP: потребление CPU при обработке злонамеренного XML через XmlStreamReader, исправляется обновлением	P1
OSV-016	OSV-Scanner	CVE-2024-38286 (Tomcat TLS handshake DoS)	orders-service/pom.xml, payments-service/pom.xml (tomcat-embed-core:10.1.20)	HIGH	0.001	0	Обновить tomcat-embed-core до 10.1.25+	TP: OutOfMemoryError через TLS handshake, исправляется обновлением	P1
OSV-017	OSV-Scanner	CVE-2026-24400 (AssertJ XXE)	orders-service/pom.xml, payments-service/pom.xml (assertj-core:3.24.2)	HIGH	0.001	0	Обновить assertj-core до 3.27.7+ или использовать XMLUnit вместо isXmlEqualTo	TP: XXE при парсинге XML, может привести к чтению файлов или SSRF, исправляется обновлением	P1
OSV-018	OSV-Scanner	CVE-2025-66566 (LZ4 Java info leak)	orders-service/pom.xml, payments-service/pom.xml (lz4-java:1.8.0)	HIGH	0.004	0	Обновить lz4-java до 1.10.1+ (или 1.8.1 с фиксом)	TP: недостаточная очистка буфера при декомпрессии, возможна утечка данных, исправляется обновлением	P1
OSV-019	OSV-Scanner	CVE-2026-54512 (Jackson PTV bypass)	orders-service/pom.xml, payments-service/pom.xml (jackson-databind:2.15.4)	HIGH	0.001	0	Обновить jackson-databind до 2.18.8+ (или 2.21.4+ / 3.1.4+)	TP: обход PolymorphicTypeValidator через generic параметры, может привести к RCE, исправляется обновлением	P1
OSV-020	OSV-Scanner	CVE-2026-54513 (Jackson array subtype bypass)	orders-service/pom.xml, payments-service/pom.xml (jackson-databind:2.15.4)	HIGH	0.001	0	Обновить jackson-databind до 2.18.8+	TP: обход allowIfSubTypesArray, позволяет создавать неразрешённые типы, исправляется обновлением	P1